

Security Operation Fundamentals

Contents

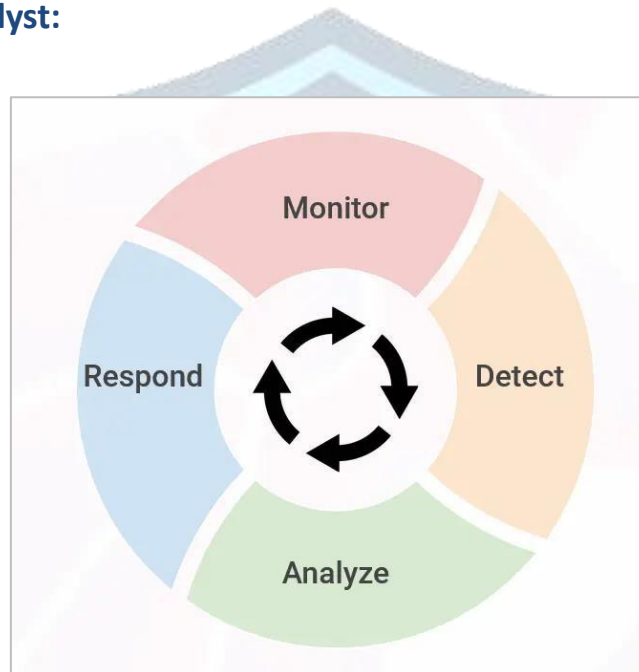
Who is a SOC Analyst ?	2
Roles of a SOC Analyst:	2
Key Functions of SOC:	4
Evolution of SOC:	5
Responsibilities and Levels of a SOC Analyst:	6
SOC Models	7
Detection outcomes in SOC	7
SOC Metrics	8
SOC Tools	9
Common Threats and Attacks	11



Who is a SOC Analyst ?

A SOC Analyst (Security Operations Center Analyst) is like a cybersecurity guard for a company. Their job is to watch over the company's computer systems, looking for any signs of trouble, like hackers or malware. They monitor alerts and logs from different systems, investigate suspicious activity, and respond to potential threats to keep the company's data safe. If they find something unusual, they figure out if it's a real problem and then take action to fix it or prevent damage.

Roles of a SOC Analyst:



Monitor:

- Continuously watches the company's network, systems, and devices for unusual or suspicious activity.
- Uses tools to collect data (like logs) from firewalls, antivirus software, and other security tools.
- **Importance:** Early detection of threats helps prevent potential attacks before they cause harm.

Detect:

- Identifies potential security threats like malware, phishing attempts, or unauthorized access.
- Sets up alerts to flag unusual activity, such as high traffic to a suspicious website.
- **Importance:** Quick detection allows the SOC team to react faster and stop attacks early.

Analyze:

- Investigates alerts to determine if they are real threats (false positives vs. actual threats).
- Studies the behavior of detected threats to understand their source, method, and target.
- **Importance:** Accurate analysis helps decide how serious the issue is and what steps to take to resolve it.

Respond:

- Takes action to neutralize or block any identified threats (e.g., blocking malicious IP addresses).
- Works with other teams to fix vulnerabilities and prevent future attacks.
- **Importance:** Effective response minimizes damage and reduces downtime, protecting the company's data and systems.

SOC Roles

SOC Analysts



Tier 1
Analyst



Tier 2
Analyst



Tier 3
Analyst



SOC Team
Lead

Specialized Roles



Incident
Responder



Threat
Hunter



Threat Intel
Analyst



Security
Engineer



Vulnerability
Manager



Forensic
Analyst



Malware
Analyst

Management Roles



SOC
Manager



Director of
Security



CISO

Key Functions of SOC:

Reactive	Proactive
Monitoring and Detection: Continuously monitors networks, systems, and logs for suspicious activities. Triggers alerts when potential security threats are detected. Ensures early identification of threats for quick action.	Threat Intelligence: Gathers information on emerging threats and attack methods. Analyzes intelligence to anticipate potential attacks. Prepares defenses against evolving threats.
Incident Response: Responds immediately to detected security incidents. Involves containing, mitigating, and recovering from the threat. Limits the attack's impact and prevents further damage.	Threat Hunting: Actively searches for hidden or undetected threats within the network. Uses advanced techniques to identify sophisticated attacks. Prevents attacks from escalating by discovering them early.
Forensics Analysis: Investigates the details of security incidents to understand how they occurred. Collects and analyzes evidence of the attacker's methods. Helps improve defenses and supports legal actions if necessary.	Vulnerability Management: Regularly scans and identifies system vulnerabilities and weaknesses. Works to patch or mitigate these vulnerabilities before exploitation. Reduces the organization's attack surface.
Malware Analysis: Analyzes malicious software to understand its behavior and origin. Identifies malware characteristics to develop defenses. Prevents similar threats from causing future damage.	Security Awareness Training: Educates employees on recognizing and avoiding cyber threats. Promotes secure behavior, reducing the risk of human error. Strengthens overall organizational security posture.

Evolution of SOC:

The evolution of SOC (Security Operations Center) can be described in 4 stages focusing on the different approaches to monitoring and automation. Here's an overview:

1. Availability Monitoring: Ensures that critical systems and services are operational and accessible. Monitors uptime and performance metrics to detect service disruptions. Facilitates rapid response to outages to minimize downtime and maintain business continuity.	2. Reactive Monitoring: Focuses on identifying and responding to security incidents after they occur. Utilizes alerts from security tools to detect anomalies and potential breaches. Aims to quickly mitigate threats and restore normal operations.
3. Proactive Monitoring: Involves continuous assessment of systems to identify potential vulnerabilities before they can be exploited. Employs advanced analytics to detect unusual patterns that may indicate emerging threats. Enables early intervention to prevent incidents from escalating into major security breaches.	4. Proactive Automation: Automates routine security tasks, such as threat detection, alert triage, and incident response. Increases efficiency by allowing analysts to focus on more complex and critical security issues. Enhances response times and reduces the likelihood of human error in security operations.



Responsibilities and Levels of a SOC Analyst:

In a Security Operations Center (SOC), responsibilities are often divided into different levels (Tier 1, Tier 2, and Tier 3), based on complexity and expertise. Here's how a typical day would break down for SOC analysts at each level.

SOC Level 1 (Tier 1): The First Line of Defense

- Monitors security dashboards and SIEM tools for low to medium priority alerts.
- Performs initial triage and analysis of alerts, distinguishing between false positives and potential threats.
- Escalates suspicious incidents to SOC Level 2 for deeper investigation.
- Documents basic incident details and updates incident tickets.
- Assists in tuning detection tools based on recurring false positives.

SOC Level 2 (Tier 2): The Incident Investigators

- Investigates escalated incidents from Level 1 using detailed log analysis, endpoint monitoring, and network traffic inspection.
- Correlates incidents with threat intelligence to identify patterns or known attack vectors.
- Leads incident containment efforts, isolating affected systems and implementing temporary fixes.
- Collaborates with SOC Level 3 for complex cases and provides guidance to Level 1 analysts.
- Engages in threat hunting activities to proactively detect undetected threats.
- Prepares detailed reports on incident investigations and response actions.

SOC Level 3 (Tier 3): The Experts and Security Architects

- Conducts deep forensic analysis, including malware reverse engineering, memory dumps, and advanced network forensics.
- Improves security architecture by identifying and addressing systemic weaknesses or vulnerabilities.
- Develops incident response strategies and coordinates recovery efforts after major incidents.
- Mentors and trains lower tier SOC analysts, sharing expertise on advanced security topics.
- Creates and refines SOC policies, procedures, and playbooks for better incident management.
- Implements security automation and orchestration to streamline response processes and enhance detection capabilities.

SOC Models:

Internal SOC (in House SOC)

- Fully managed by the organization's internal team.
- Provides complete control over security operations and tools.
- Requires significant investment in staff, infrastructure, and security technologies.
- Tailored to the organization's specific needs and compliance requirements.
- Enables fast response to incidents due to direct control.
- Can be costly due to staffing, technology maintenance, and continuous training.

Managed SOC (Outsourced SOC)

- Operated by an external Managed Security Service Provider (MSSP).
- Offers limited control for the organization as security operations are handled externally.
- More cost effective, as resources are shared across multiple clients.
- Provides access to a broader range of expertise and UpToDate security technologies.
- May experience slower response times and dependency on third party management.
- Ensures lower operational costs but raises concerns over data confidentiality.

Hybrid SOC

- Combines internal security operations with external provider support.
- Balances control between the organization and the managed service provider.
- Allows flexibility by keeping critical functions inhouse and outsourcing specific tasks.
- Helps scale SOC operations efficiently while maintaining important data internally.
- Reduces costs while maintaining some level of customization and security expertise.
- May involve complexity in coordination and communication between internal and external teams.

Detection outcomes in SOC:

1. True Positive:

A legitimate security threat that corresponds to real malicious activity or an active attack.

2. False Positive:

The system incorrectly flags normal activity as a threat, leading to unnecessary alerts and investigation.

3. True Negative:

The system correctly identifies that no threat is present and does not generate an alert, ensuring normal activity continues without interruption.

4. False Negative:

A real security threat goes undetected. The system fails to generate an alert, allowing the threat to persist unnoticed.

SOC Metrics:

1. MTTD (Mean Time to Detect): Average time taken to detect a security incident after it occurs.	2. MTTR (Mean Time to Respond): Average time between detecting an incident and initiating response actions.
3. MTTA&A (Mean Time to Acknowledge & Analyze): Average time it takes to acknowledge and analyze an alert before further investigation.	4. Incident Detection Rate: Percentage of security incidents successfully detected by the SOC.
5. FPR (False Positive Rate): Percentage of alerts flagged as threats that turn out to be false positives.	6. FNR (False Negative Rate): Percentage of actual threats that go undetected by the SOC.
7. KPI (Key Performance Indicators): Metrics that measure the performance and efficiency of SOC operations, such as incident response times and alert accuracy.	8. KRI (Key Risk Indicators): Metrics that indicate potential risk exposure, measuring the likelihood of security incidents and their potential impact.
9. SLAs (Service Level Agreements): Defined performance expectations between the SOC and stakeholders, ensuring timely detection, response, and resolution of incidents.	

**CYBER
WARRIORS**

SOC Tools:

1. SIEM (Security Information and Event Management)

- **Splunk:** Aggregates logs and data from various sources to provide Realtime analysis and visualizations.
- **IBM QRadar:** Detects and responds to threats using machine learning and analytics on collected data.
- **ArcSight:** Correlates security events and delivers insights through comprehensive monitoring and reporting.

2. SOAR (Security Orchestration, Automation, and Response)

- **Palo Alto Cortex XSOAR:** Automates incident response workflows and integrates with multiple security tools.
- **Splunk Phantom:** Automates repetitive tasks and orchestrates responses to security threats.
- **Demisto:** Facilitates incident management through automation and collaboration.

3. Incident Management Tools

- **ServiceNow:** Manages security incidents and integrates with other security platforms for tracking and response.
- **PagerDuty:** Alerts security teams to incidents and helps coordinate responses.
- **Jira:** Tracks incidents, facilitates issue management, and allows collaboration across teams.

4. NSM (Network Security Monitoring)

- **Zeek (formerly Bro):** Monitors network traffic and provides logs for forensic analysis and intrusion detection.
- **Suricata:** Network security engine that provides Realtime intrusion detection and prevention.
- **Security Onion:** Full platform for NSM, including IDS, packet capture, and analysis tools.

5. IDS/IPS (Intrusion Detection and Prevention Systems)

- **Snort:** Opensource IDS/IPS that detects malicious activity based on rules.
- **Suricata:** High performance IDS/IPS with capabilities for intrusion detection, traffic analysis, and rule-based prevention.
- **Cisco Firepower:** Combines IDS/IPS with firewall features for detecting and blocking threats.

6. EDR (Endpoint Detection and Response)

- **CrowdStrike Falcon:** Provides continuous monitoring and detection of endpoint threats and incidents.
- **Carbon Black:** Offers Realtime threat detection and response across endpoints.
- **Microsoft Defender for Endpoint:** Detects and responds to advanced threats targeting endpoints.

7. Firewalls

- **Palo Alto Networks:** Provides NextGen firewalls with advanced threat protection, application visibility, and user control.
- **Cisco ASA:** Offers a combination of firewall, VPN, and IPS for securing networks.
- **Fortinet FortiGate:** Delivers enterprise level firewall protection and threat management.

8. TIP (Threat Intelligence Platforms)

- **Anomali:** Aggregates threat intelligence feeds and integrates with existing security tools for actionable insights.
- **ThreatConnect:** Enables organizations to automate threat intelligence processes and operationalize data.
- **MISP (Malware Information Sharing Platform):** Opensource platform for collecting, sharing, and correlating threat intelligence.

9. Forensic Analysis Tools

- **Autopsy:** Opensource digital forensics tool for file and disk image analysis.
- **EnCase:** Widely used for forensic analysis of hard drives, mobile devices, and networks.
- **FTK (Forensic Toolkit):** Comprehensive suite for disk imaging, password recovery, and forensic analysis.

10. Malware Analysis Tools

- **Cuckoo Sandbox:** Opensource tool that runs suspicious files in a virtual environment to analyze their behavior.
- **Remnux:** Linux based toolkit for reverse engineering and analyzing malware.
- **IDA Pro:** Advanced tool for reverse engineering, providing detailed analysis of malware binaries.

Common Threats and Attacks:

Common cybersecurity threats and attacks can vary widely, targeting different aspects of an organization's infrastructure. Below are some of the most prevalent types:

Common Threats:

1. **Malware:**

- **Viruses:** Malicious code that attaches itself to clean files, spreading to other files and causing damage.
- **Worms:** Self-replicating malware that spreads across networks, exploiting vulnerabilities.
- **Trojan Horses:** Malware disguised as legitimate software to trick users into installing it.
- **Ransomware:** Encrypts files and demands a ransom for decryption keys.
- **Spyware:** Secretly monitors user activity and collects data without consent.

2. **Phishing:**

- **Email Phishing:** Fraudulent emails tricking users into divulging personal information or clicking malicious links.
- **Spear Phishing:** Targeted phishing attack aimed at specific individuals or organizations.
- **Whaling:** Phishing attacks targeting high profile individuals like executives (CEO fraud).

3. **Denial of Service (DoS) and Distributed Denial of Service (DDoS):**

- **DOS:** Overloads a system with traffic, causing it to crash and become unavailable to users.
- **DDOS:** Uses multiple systems (often hijacked devices) to flood a target with excessive traffic, overwhelming the service.

4. **Man in the Middle (MitM) Attacks:**

Attackers intercept communications between two parties to eavesdrop or alter the data being transmitted.

5. **Advanced Persistent Threats (APTs):**

Long term, targeted attacks where adversaries infiltrate a network and remain undetected to steal sensitive data over an extended period.

6. **Insider Threats:**

Malicious activities conducted by current or former employees, contractors, or trusted individuals with access to an organization's systems or data.

Common Attacks:

1. SQL Injection:

Attackers insert malicious SQL queries into input fields to manipulate databases, potentially gaining access to sensitive information.

2. Cross Site Scripting (XSS):

Injects malicious scripts into web pages viewed by users, allowing attackers to steal cookies, session tokens, or redirect users to malicious websites.

3. Brute Force Attacks:

Automated attempts to guess passwords, encryption keys, or PINs through exhaustive trial and error.

4. Credential Stuffing:

Attackers use stolen login credentials from one breach to attempt logins on other sites, leveraging password reuse by users.

5. Zero Day Exploits:

Attacks that exploit vulnerabilities in software that are unknown to the vendor and have no patches available.

6. Social Engineering:

Psychological manipulation of individuals to divulge confidential information, often through impersonation or deceptive scenarios.

- **Pretexting:** Creating a fabricated scenario to obtain private information.
- **Baiting:** Using false promises or free offers to trick victims into giving up credentials or downloading malware.

7. Password Attacks:

- **Dictionary Attacks:** Using a list of commonly used passwords to gain access.
- **Keyloggers:** Capturing keystrokes to record passwords and other sensitive data.

8. Rogue Software:

Fake software designed to look legitimate but is malware that harms the system or steals data.

9. Session Hijacking:

Attacker takes control of a user session by stealing or forging session tokens used to authenticate and maintain user identity during web browsing.